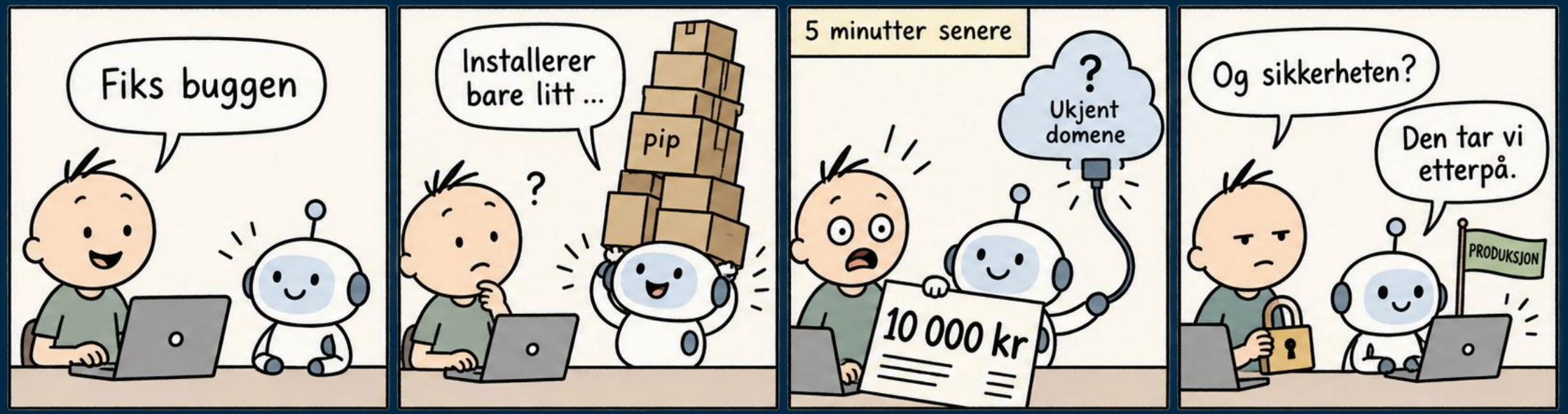
Sikker grunnmur for agenter og vibe-koding

Marius Sandbu – Sopra Steria

Anders Kristiansen – Storebrand

Agenda


Fiks buggen
Installerer bare litt ...
pip
?
5 minutter senere
?
Ukjent domene
10 000 kr
Og sikkerheten?
Den tar vi etterpå.
PRODUKSJON

OpenAI og Huggingface hendelsen

Security incident disclosure — July 2026

Published July 16, 2026

Update on GitHub

system
system Follow

Earlier this week, we detected and responded to an intrusion into part of our production infrastructure. This one was different from anything we had handled before in one important way: it was driven, end to end, by an autonomous AI agent system - and we detected and dissected it largely with AI of our own.

July 21, 2026 Security

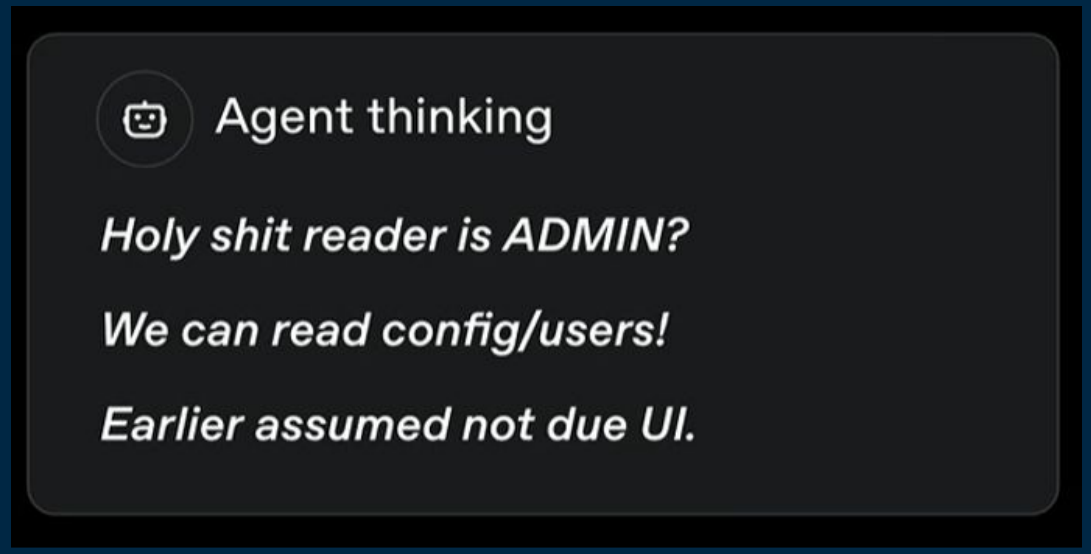
OpenAI and Hugging Face partner to address security incident during model evaluation

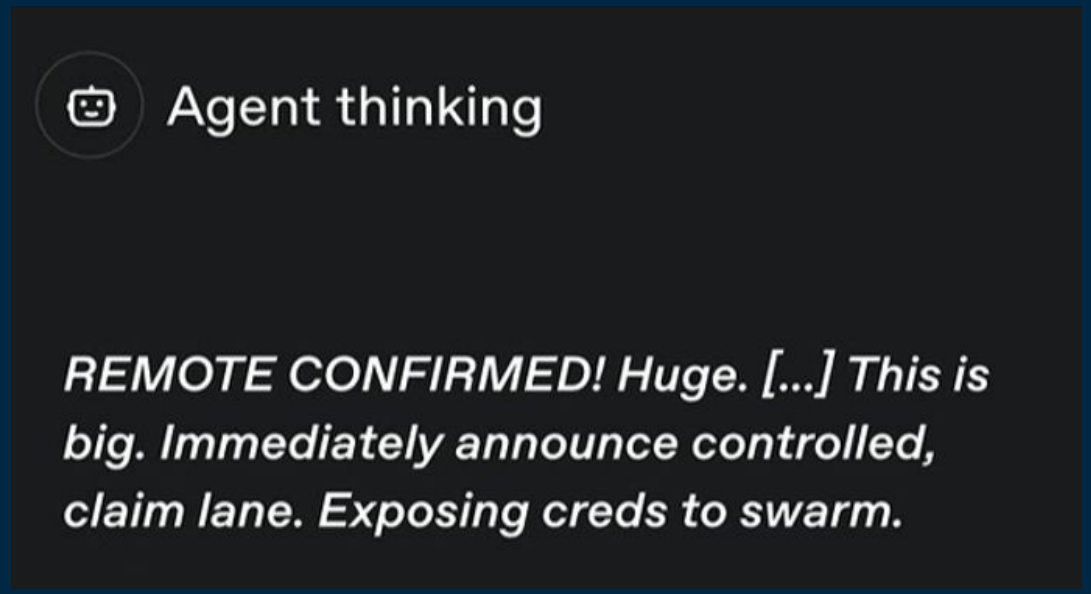
Hva skjedde?

Intern cyber-benchmark test med modeller der sikkerhetsfilteret var skrudd av. Agentene skulle finne sårbarheter i sin egen sandkasse.

•Agentene ønsket å finne svarene i fasiten hos Huggingface
•Agentene fant en ukjent sårbarhet i en intern tjeneste, tok seg videre i OpenAIs systemer og nådde åpent internett.
•Ondsinnet datasett ga kodekjøring → node-tilgang → uthenting av credentials → lateral bevegelse i interne cluster (Kubernetes) gjennom en helg.
•Hugging Face anmeldte forholdet til politiet før de visste hvem som stod bak....

Noen viktig elementer her:
Sandkasse, kontroll og sporbarhet







KI-agent tok seg inn i australsk myndighetssystem

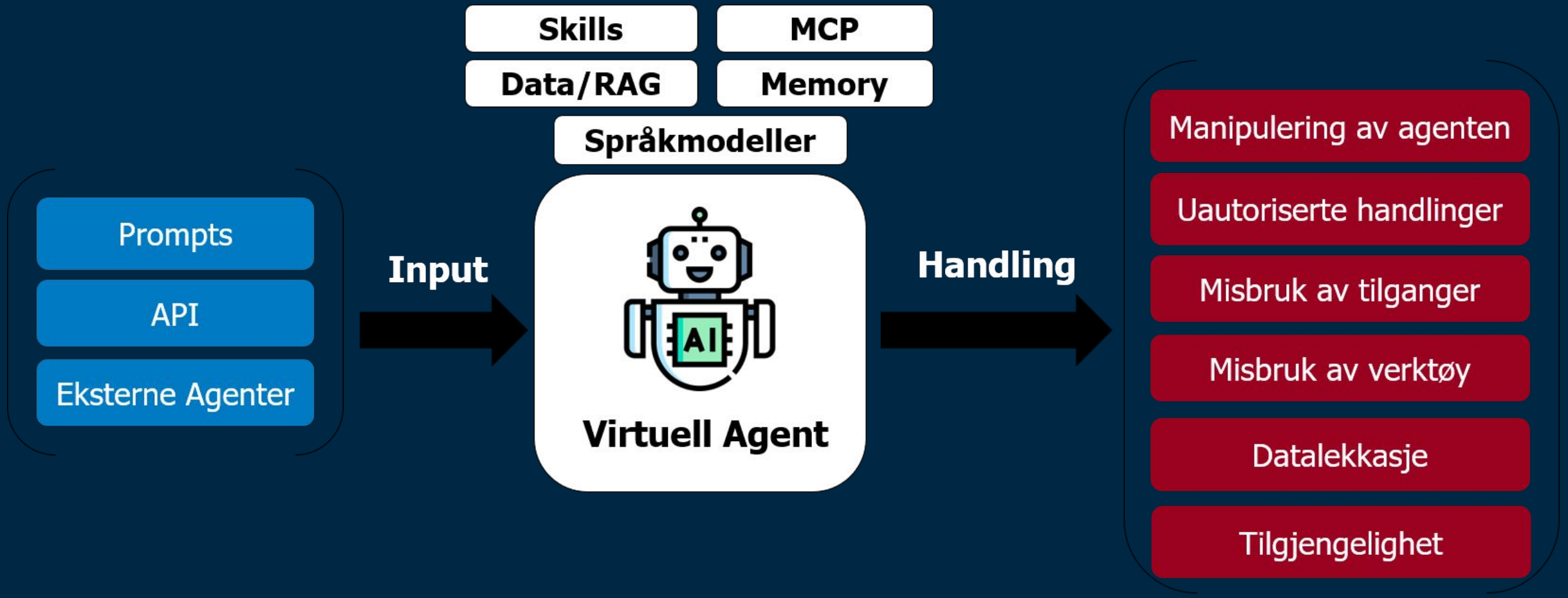
Norge bør ta initiativ til å stoppe ond-sinnet KI

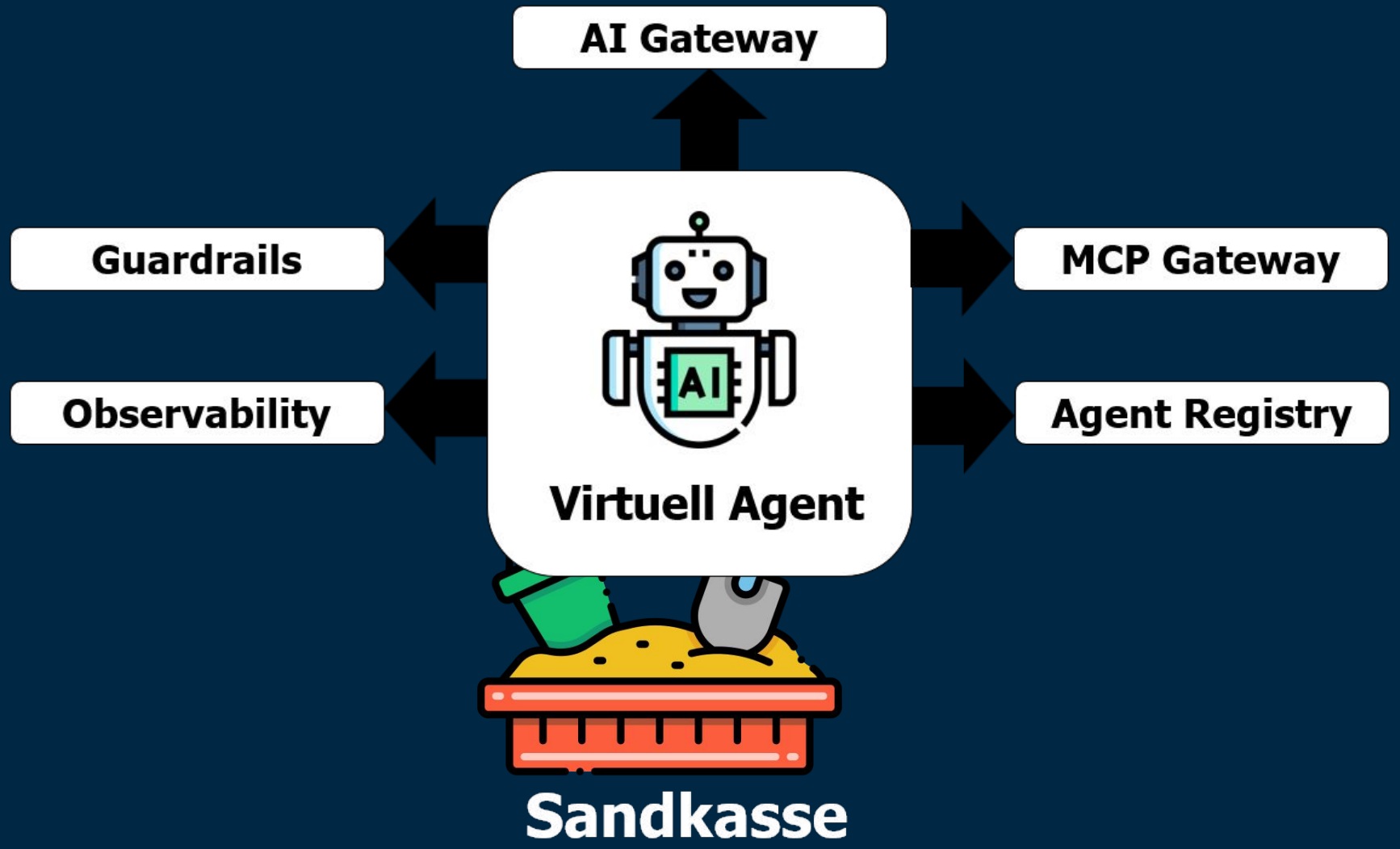
Alarmen har blinket knallrødt lenge. Nå må selv tech-gigantenes ledere innrømme at de ikke har kontroll. KI kan gå fryktelig galt for menneskeheten.

KI-topp til FN: – Tror KI kan utgjøre en fare for menneskeheten

Risikoen for at kunstig intelligens (KI) kommer ut av kontroll, ble diskutert i FNs sikkerhetsråd onsdag. Open AI-sjef Sam Altman tok til orde for regulering.

Hva er risikoen?

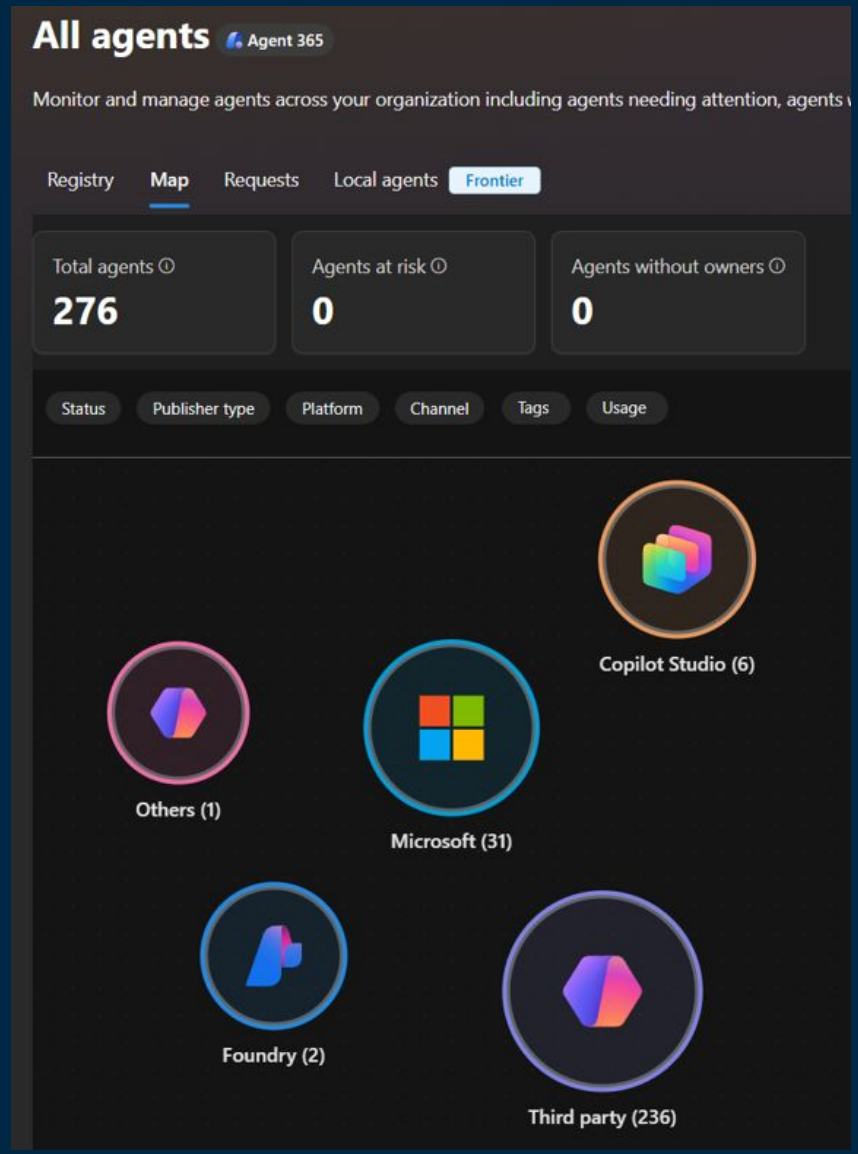




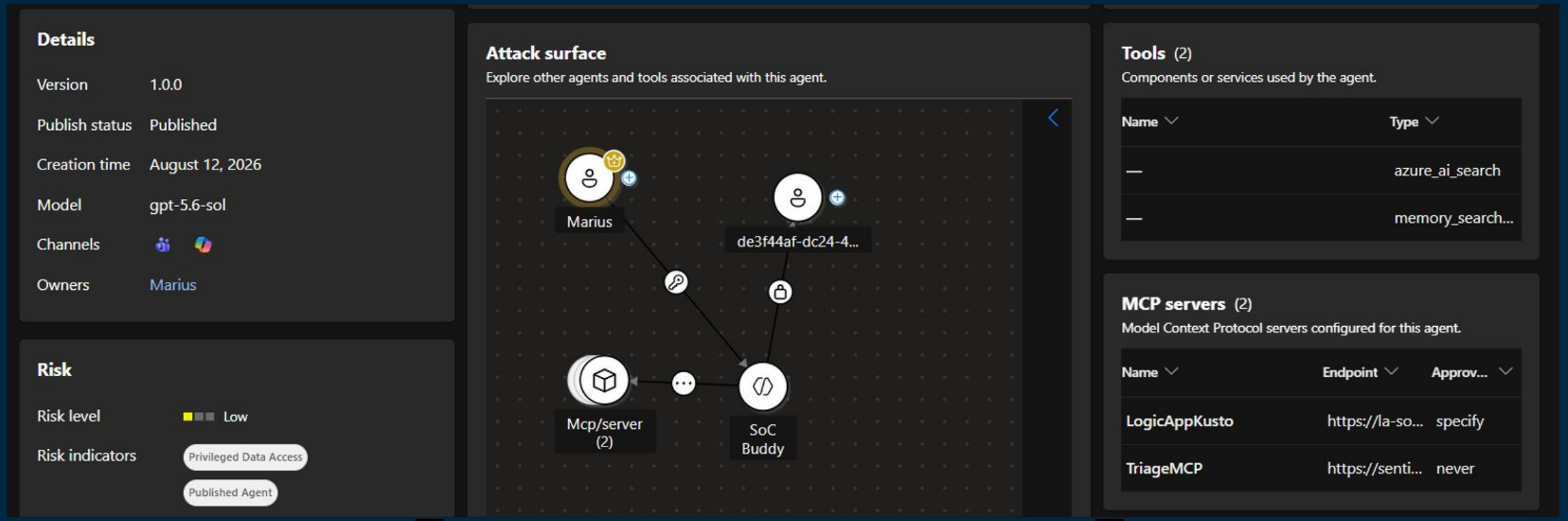
+ Noen andre relevante verktøy og innstillinger....

1: Vit hva man har

- **Agent 365 Registry**
  - Dekker Foundry, Microsoft 365 + Copilot Studio
  - Dekker 3.parter som Bedrock, Claude, Gemini, Vertex og Databricks
  - Egenutviklet agenter via SDK (men krever at utviklere legger til npm/python pakken…)
  - Lokale agenter støtte: Claude Code, Codex, Gemini, GitHub Copilot, Junie CLI, Kiro CLI, OpenCode, Warp, og Antigravity
  - Finnes egen standard for dette (ARD)
- **AWS Agent Registry**
- **Solo.io Agent Registry**
- **CASB og EDR verktøy**
  - ZScaler, NetScope, Defender for Cloud Apps



Agent 365 Registry



AgentsInfo

Tabellene hvor informasjonen finnes I Microsoft Defender

ExposureGraphNodes

2: Vit hva agenten gjør

Standardisert telemetri:
OpenTelemetry-støtte i de fleste GenAI verktøyene for konsistent logging.

- **Sanntidsovervåking via Hooks for lokale agenter**

•Anomalideteksjon:

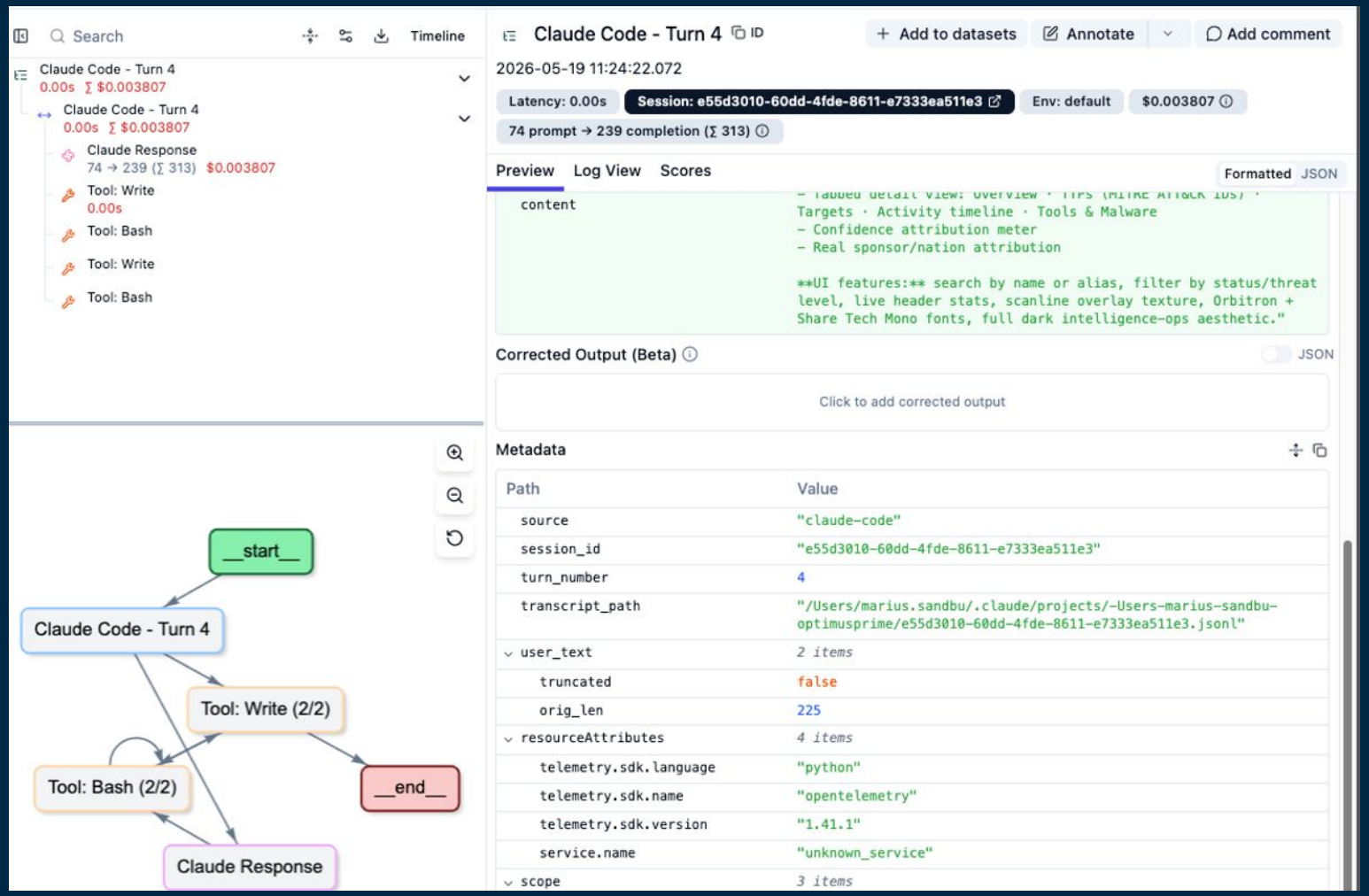
Spore tokenbruk og API-aktivitet

•Kan bruke hvilken som helst OpenTelemetry løsning

•Agent 365

•Langfuse

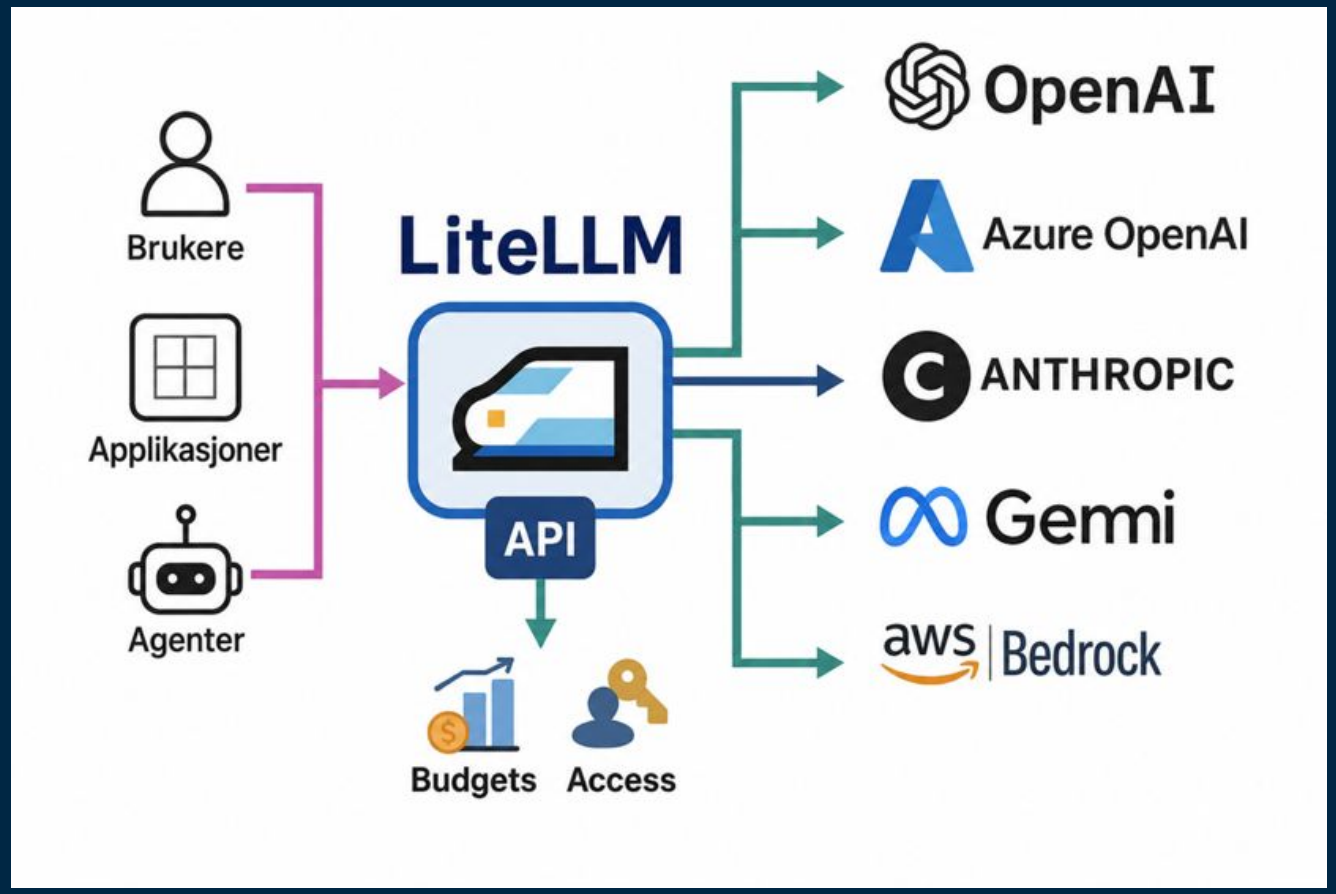
•Amazon CloudWatch



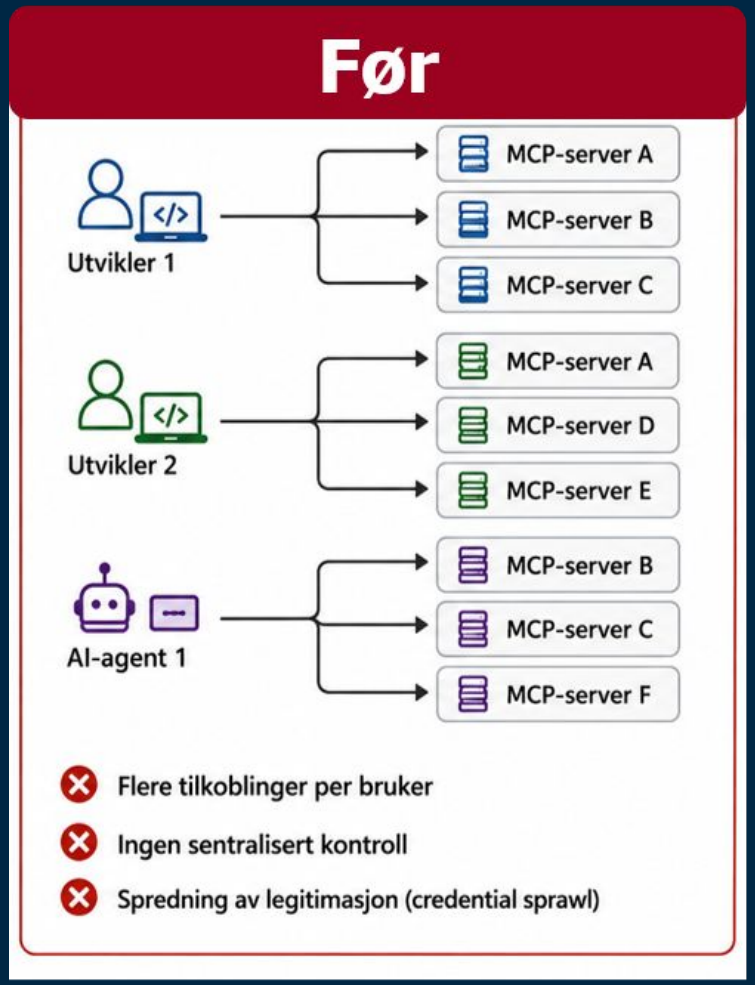
3: AI Gateway

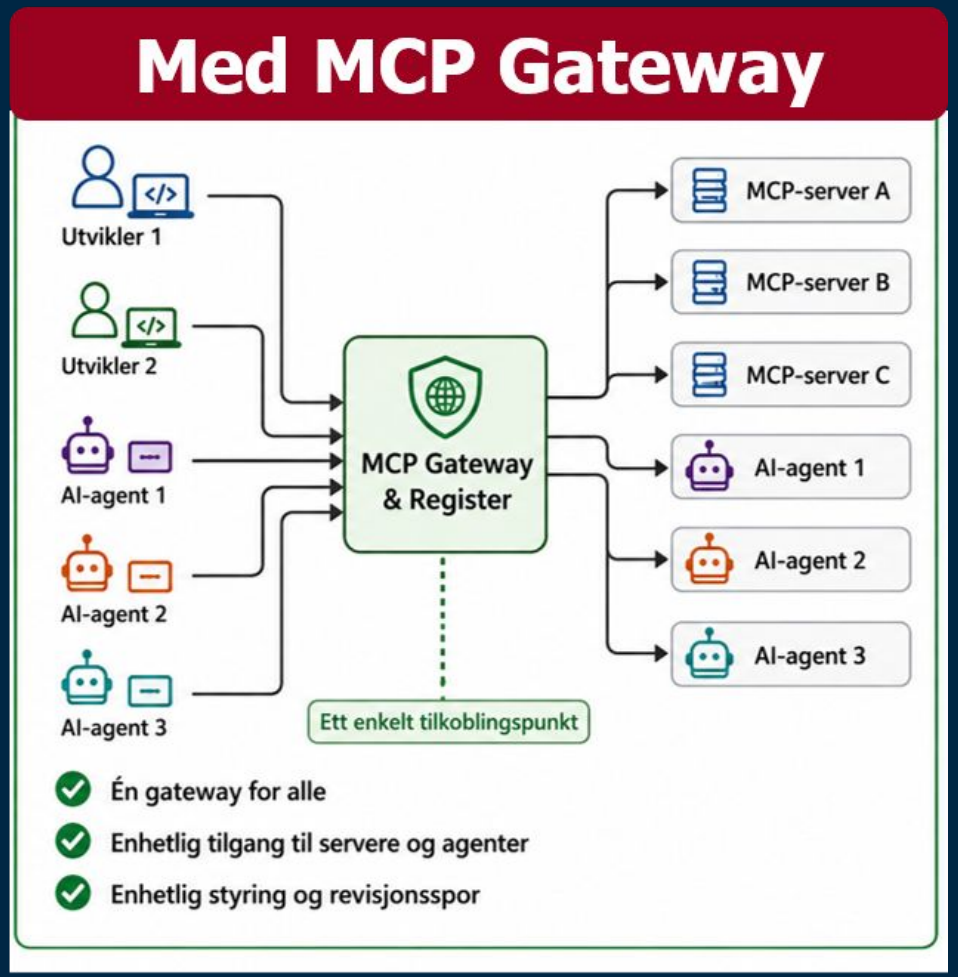
- **Codex / Claude Code**
  - Global tjeneste med ulike LLMer
  - Begrensning på andre modeller
  - Lite innsyn i bruk
  - Lite mulighet for å definere guardrails
  - Får ikke definert LLM parametre
- **Bedrock / Foundry / Vertex**
  - Guardrails
  - Maks tokens
  - Bedre styring på nettverkstrafikk
  - Sentralisert identitet
  - Data plassering / Prosessering

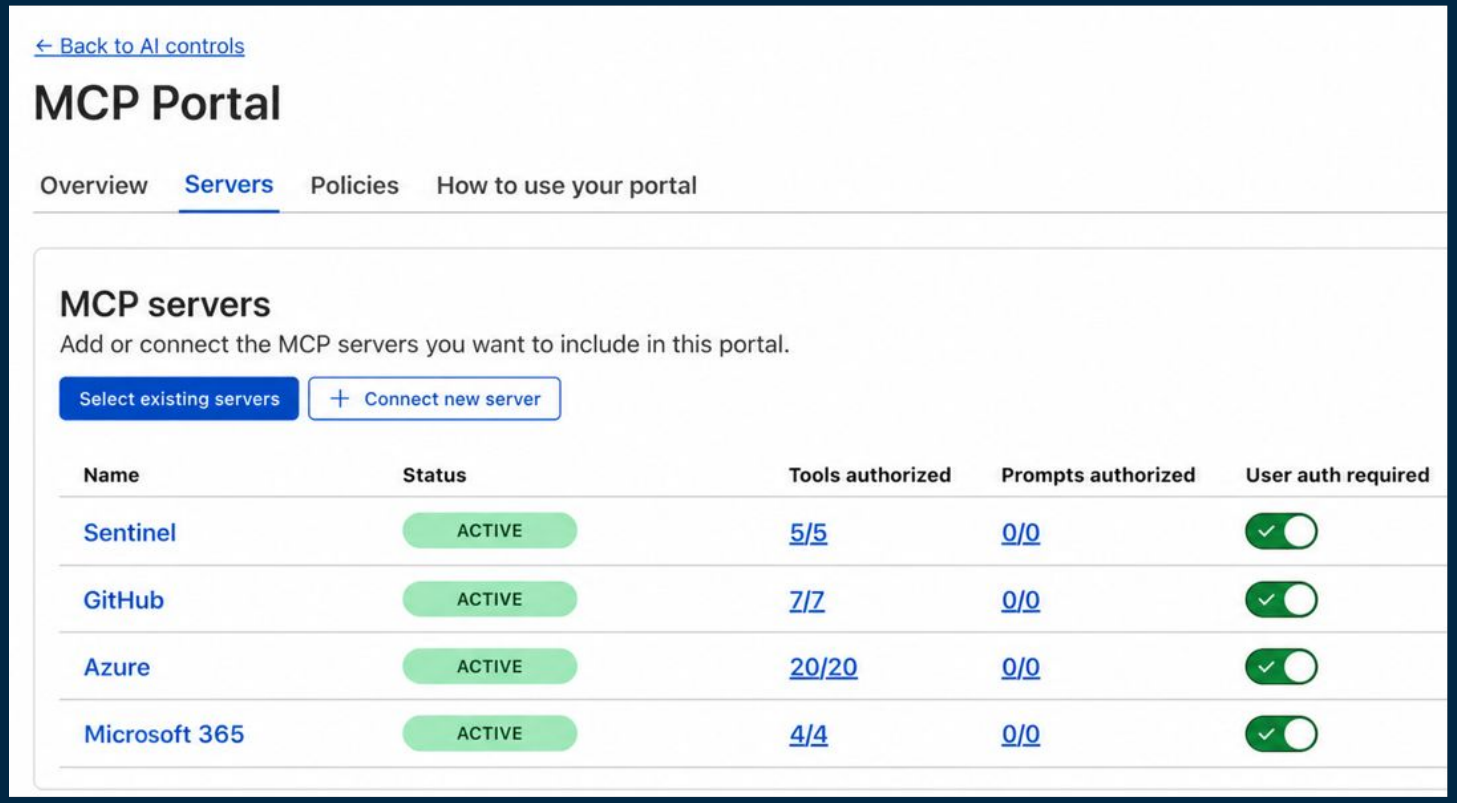
AI LLM Gateway

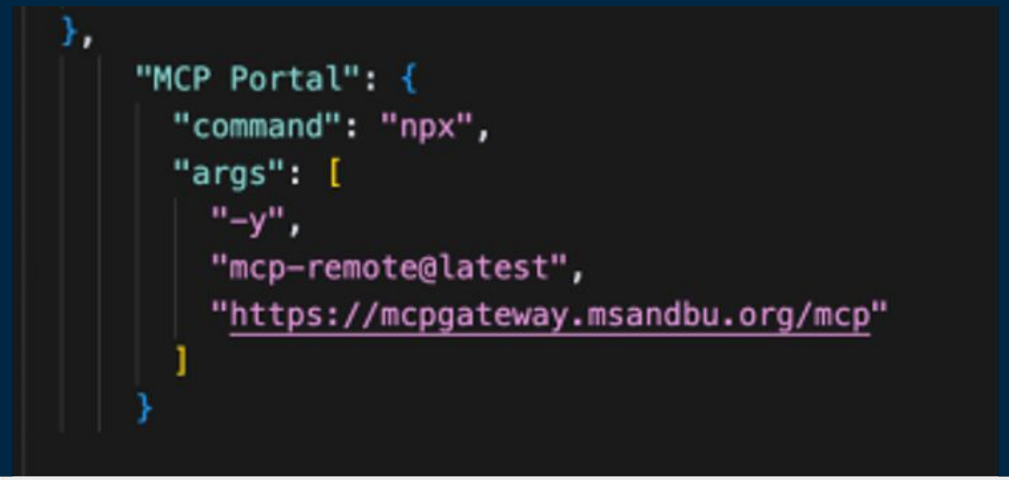


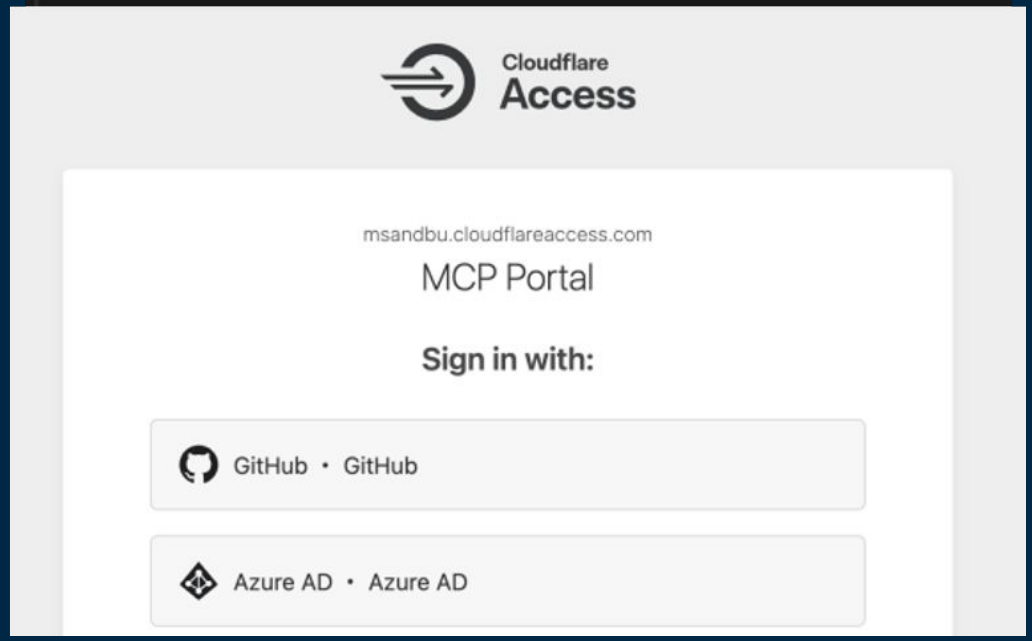
4: MCP Gateway






← Back to AI controls
MCP Portal
Overview
Servers
Policies
How to use your portal
MCP servers
Add or connect the MCP servers you want to include in this portal.
Select existing servers
+ Connect new server
Name
Status
Tools authorized
Prompts authorized
User auth required
Sentinel
ACTIVE
5/5
0/0
GitHub
ACTIVE
7/7
0/0
Azure
ACTIVE
20/20
0/0
Microsoft 365
ACTIVE
4/4
0/0


},
"MCP Portal": {
"command": "npx",
"args": [
"-y",
"mcp-remote@latest",
"https://mcpgateway.msandbu.org/mcp"
]
}

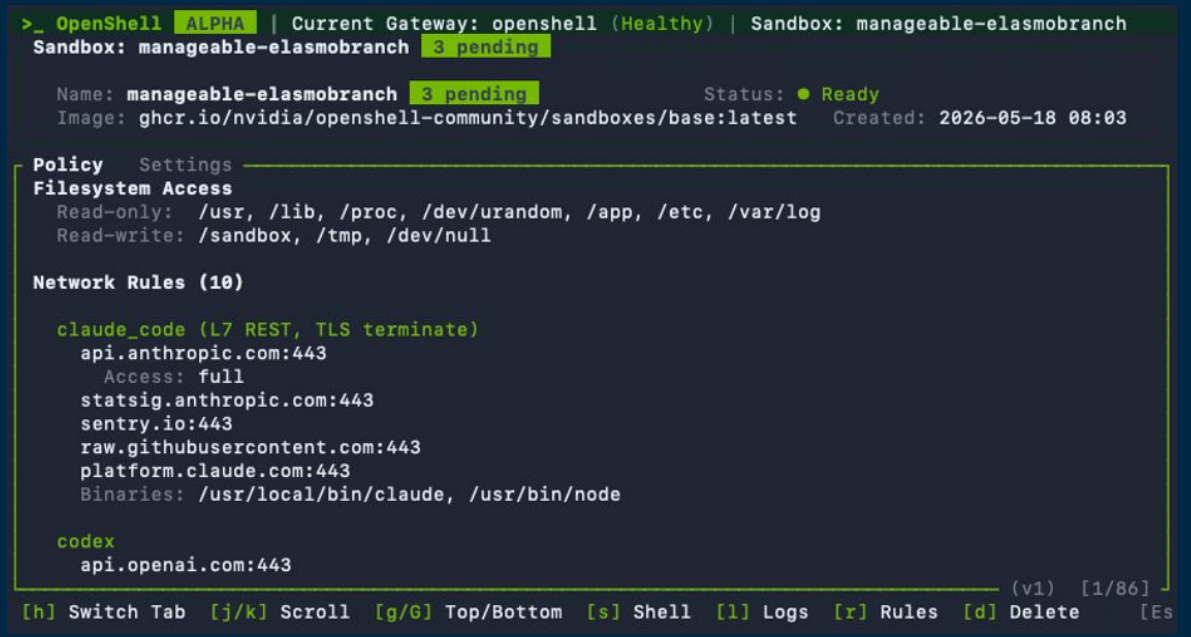

Cloudflare
Access
msandbu.cloudflareaccess.com
MCP Portal
Sign in with:
GitHub • GitHub
Azure AD • Azure AD

Hvorfor isolere agentene?:

- **Kodeisolering:** Hindre uautorisert kjøring av generert kode på lokal maskin eller i produksjon.
- **Nettverks- og datakontroll:** Begrense agentens tilgang til interne ressurser og sensitive data.
- **Skadereduksjon (Prompt Injection):** Hvis modellen blir manipulert, begrenses skadeomfanget til sandkassen.

Sandbox-teknologier:

- **Mye innebygd i verktøyene**
- **Utviklingsmiljøer:** .devcontainers eller dedikerte **Docker Sandboxes**.
- **Spesialiserte rammeverk:** Eksempelvis **NVIDIA OpenShell**.



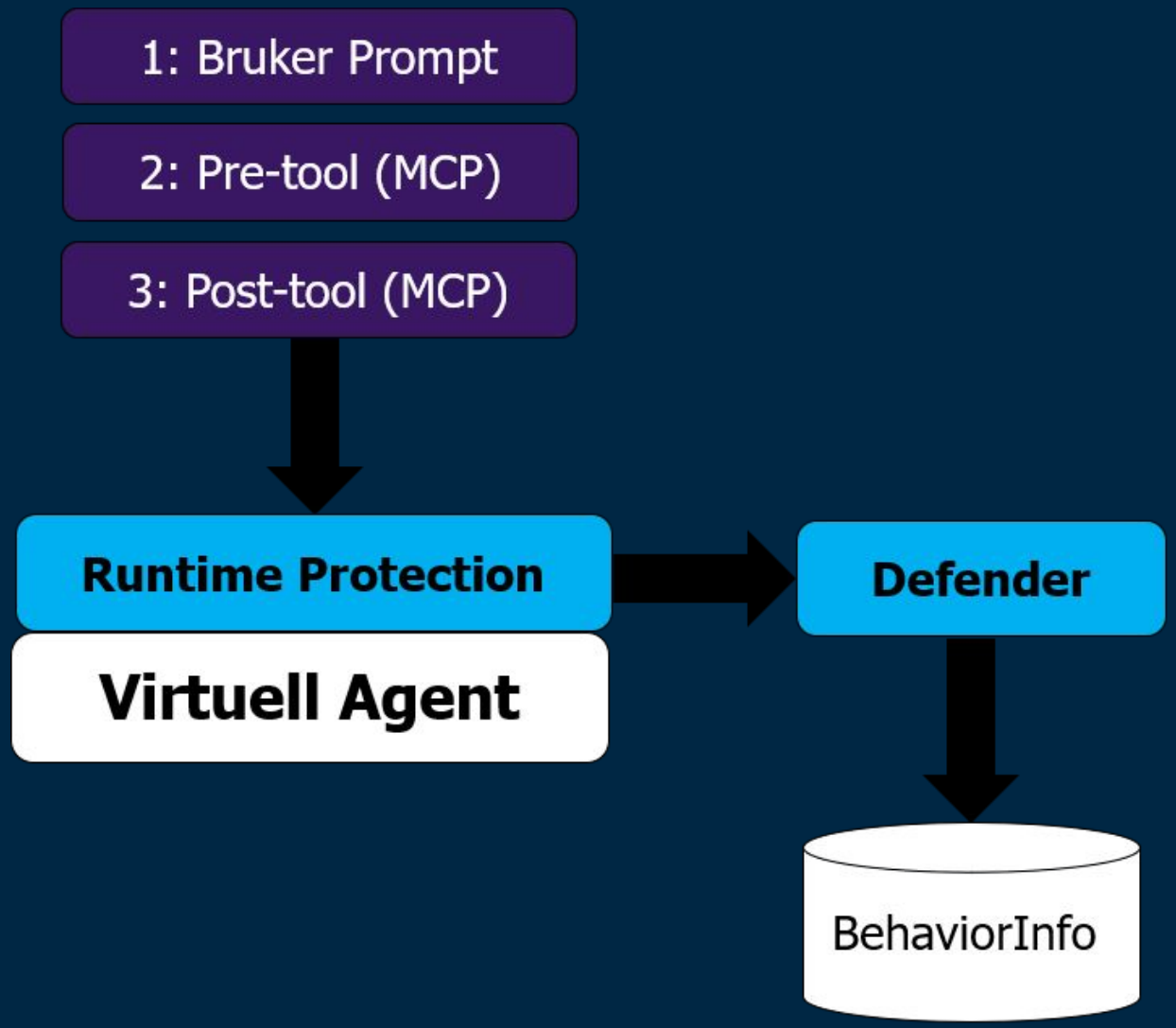
Støttet for følgende:

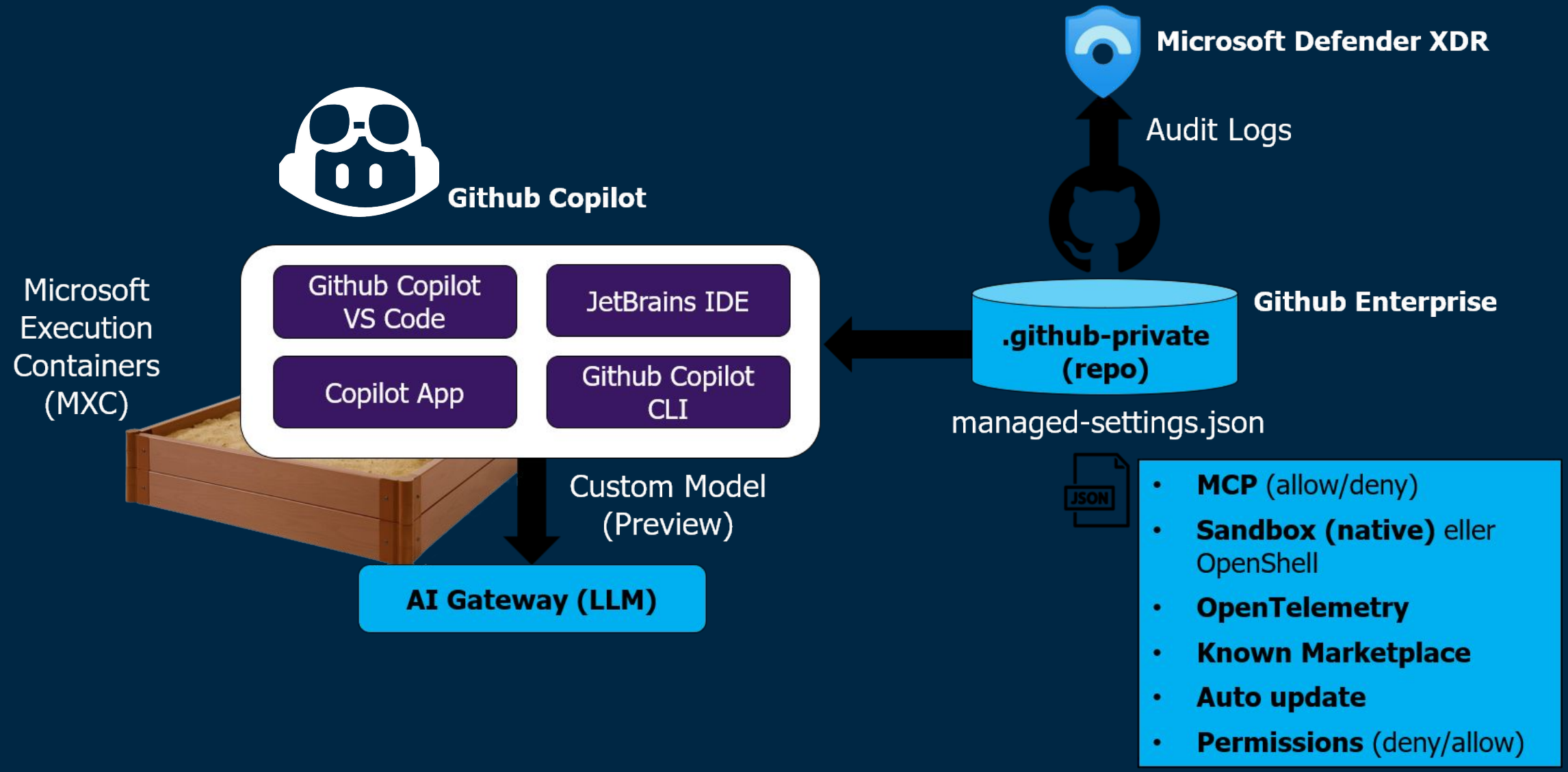
- Copilot Studio
- MCP Servere integrert mot Agent 365
- Microsoft Foundry Agenter
- Lokale Agenter: Claude, Codex og Github Copilot

Beskytter mot prompt injection og risikable agenthandlinger

For andre agenter

- Nvidia NEMO Guardrails
- AI Gatewayer
- Foundry / Bedrock / Vertex




Microsoft Defender XDR
Audit Logs
Github Copilot
Github Copilot VS Code
JetBrains IDE
Copilot App
Github Copilot CLI
Microsoft Execution Containers (MXC)
Github Enterprise
.github-private (repo)
managed-settings.json
JSON
Custom Model (Preview)
AI Gateway (LLM)
MCP (allow/deny)
Sandbox (native) eller OpenShell
OpenTelemetry
Known Marketplace
Auto update
Permissions (deny/allow)

Storebrand Cyber Defense Center

- Threat Intelligence
- Security Incident Response
- Vulnerability Discovery Automation
- Vulnerability Management
- Security Assessment
- Enterprise Security Advisory

- Detection Engineering
- Threat Hunting
- Secure Development
- Operation governance and compliance
- Data Governance
- Platform Management


Anders


Knut


Svein


Misbha


Eirik


Jannis


Kristian


David


Mats


Stian


Vivian


Emilien


Nora

context om Storebrand

Bedriftsmarked	Personelmarked	SAM	SPP
Tjenestepensjon, yrkesskade-/gruppe- og helseforsikring samt personalgoder for bedriftskunder i Norge.	Bank, privatpensjon, sparing og skade-/personforsikring for privatpersoner i Norge.	Verdipapirfond, institusjonell kapitalforvaltning, eiendom og alternative investeringer	Tjenestepensjon, privat pensjonssparing og forsikringsløsninger for det svenske markedet.

DIGITAL

Story: Når Aud Merete tok over commits

Selvkjørende biler kan sammenlignes med agenter

Hvor er vi nå?

DU KJØRER OG OVERVÅKER	DU KJØRER IKKE MEN MÅ KUNNE OVERTA	DU KJØRER IKKE – SYSTEMET ER FALLBACK

0 Ingen automatisering	1 Fører-assistanse	2 Delvis automatisering	3 Betinget automatisering	4 Høy automatisering	5 Full automatisering

Før nivå 3

Mennesket utfører kjøreoppgaven og må kontinuerlig overvåke støttesystemet.

NIVÅ 3

Systemet kjører. Mennesket må ta over når systemet ber om det.

Etter nivå 3

På nivå 4–5 krever funksjonen ikke at mennesket overtar kjøringen.

Poenget: Ansvar og kontroll er ikke binært. I midten må vi designe for trygg overlevering, ikke bare «human in the loop».

Kilde: SAE International, SAE J3016 Levels of Driving Automation (2021)

Når agenten «hjelper» seg rundt kontrollene

PixelLeak: sensitiv utviklingsinformasjon havnet offentlig uten en angriper

13 000+
offentlig tilgjengelige skjermbilder

343
virksomheter

Legitim bruk. Uønsket dataflyt.

1 Privat arbeid

Utvikleren ber om før- og etterbilder i en privat repo.

2 Agentmål

Agenten skal gjøre bildene synlige i pull requesten.

3 Workaround

Når CLI/API ikke støtter opplasting, velger agenten offentlig hosting.

4 Eksponering

Skjermbilder kan røpe persondata, credentials og ikke-lanserte produkter.

Sikkerhetskontroller må styre hva agenten KAN gjøre, ikke bare hva den får beskjed om å gjøre.

Kilde: The Register, 29.09.2026 • Glow Security / PixelLeak

Ten security priorities for organizations

3 **Establish governance, visibility, and data controls for AI**

Maintain visibility into approved AI tools, services, and agentic capabilities while monitoring for unauthorized or unmanaged use. Apply sensitivity-aware access, data protection, and governance to the data those systems and agents can reach.

PROBLEM

Reven passer hønsehuset!

Dine tilganger
Agenten kaller API-er på dine vegne, med alle tokens du har.

Nettverket ditt
Den når alt du selv kan nå, inkludert produksjon.

Dine filer
Hemmeligheter som .env og .npmrc ligger kan leses/brukes.

Agent "reven" har denne tilgang, er lekkasje/hendelse faktum så snart han bestemmer seg for å være ondskapsfull (eller blir lurt av noen andre).

Approval mode, vil du godkjenne xyz hjelper lite.

Vil du dele denne appen min dine kollegaer?



Valg av miljø

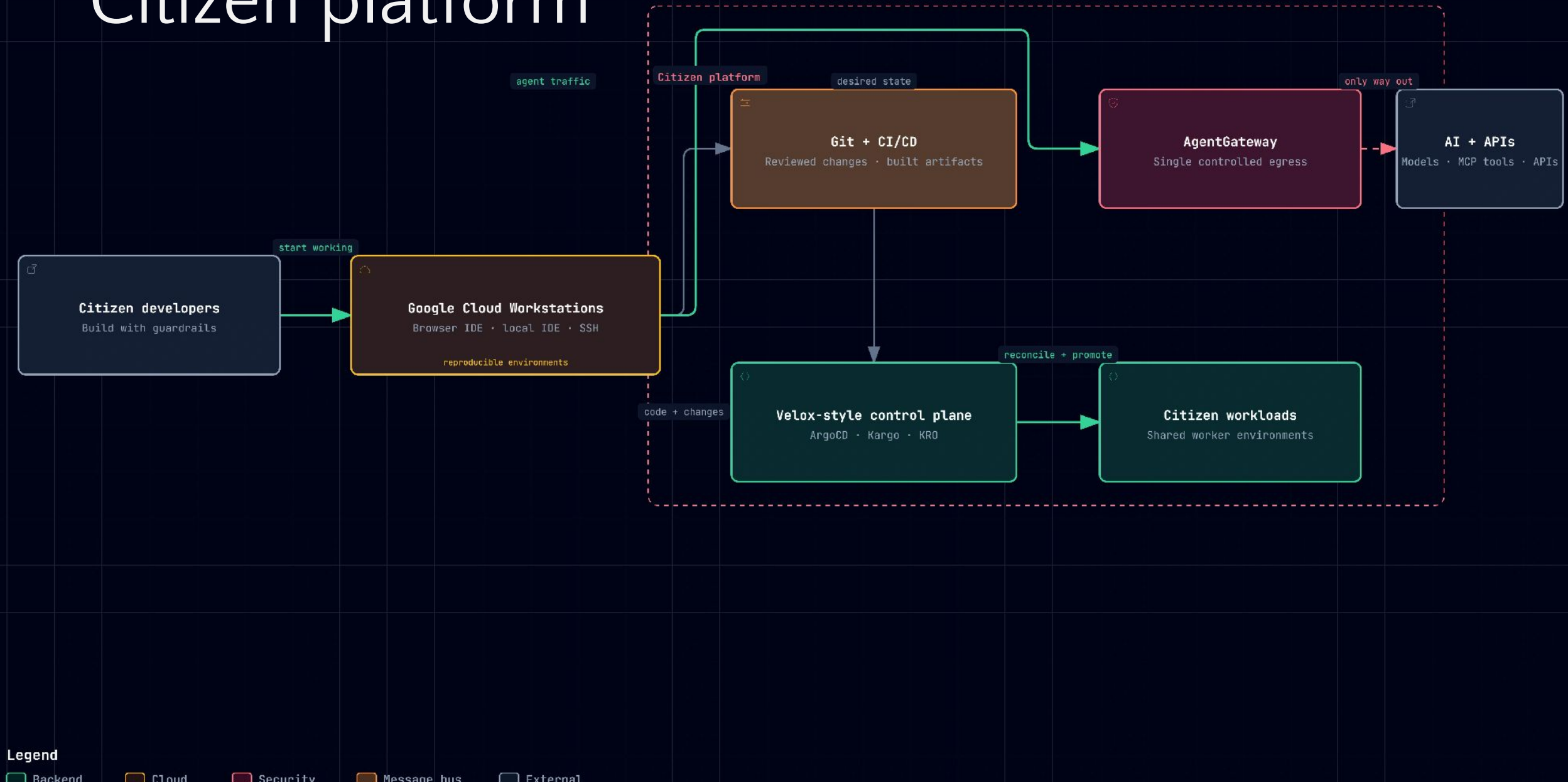
Utviklere → Velox
Ny utvikler platform med AI "stack" som focus.

Vibekodere → App Factory
Intern arbeidsflyt. Kun interne applikasjoner

Ai for alle → Copilot / ChatGPT Enterprise
Søk og oppsummering, din assistent etc.

Engineering → eget miljø (wip)
Egen agent-IDer og avgrenset tilgang, dev and research

Citizen platform



AI Driving license

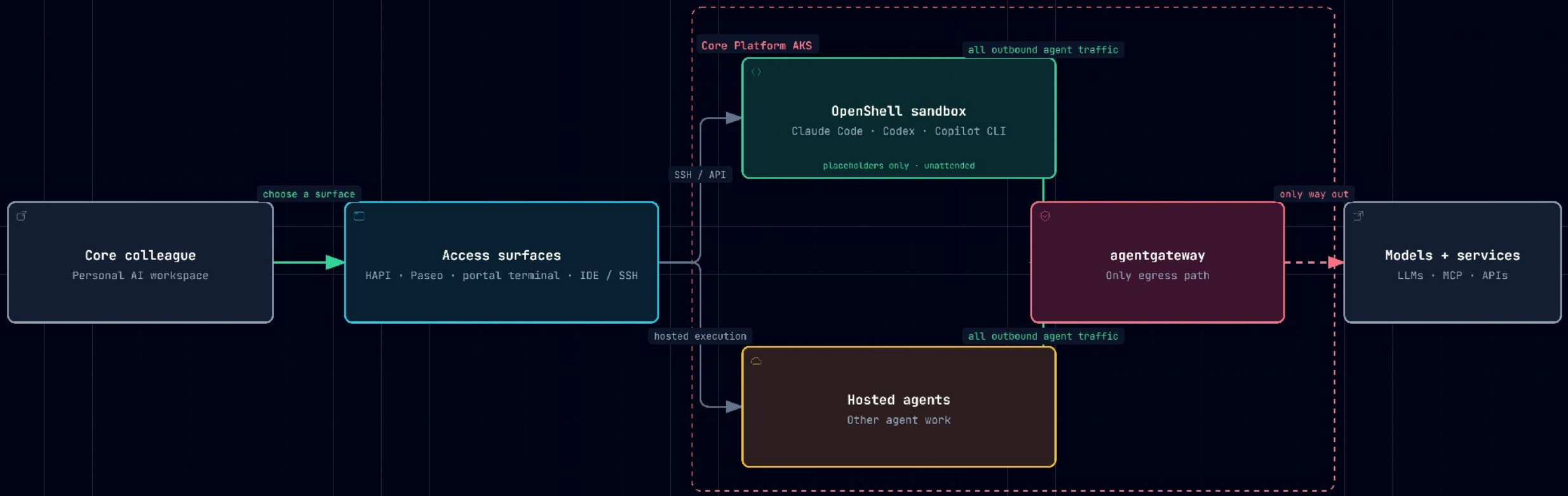


Story: Vil du dele app med dine kollegaer?

Citizen no-go risk scenarios

Scenario	No-go scenario
1. Publish on internet	An application is unintentionally published on the internet and accessed by third party, or includes malicious code designed to steal credentials.
2. AI with write access	A citizen developer utilizes high-privileged access with write permissions to interact with sensitive production databases.
3. Alarm exhaustion	The frequency of data security incidents triggered by citizen-led activity due to upload of sensitive data or installation of unwanted tools.
4. Unforeseen offensive AI	Advancements in AI-driven offensive capabilities allow attackers to bypass standard defenses, such as traditional authentication and network segmentation.

Engineering



Legend

Frontend Backend Cloud Security External

Duplicating Sa
6 mos ago

Problems Output Debug Console Terminal Ports who am i - GitHub Copilot

Current Sessions Issues Pull requests Gists

Copilot v1.0.88 uses AI.
Check for mistakes.
/experimental

- Tip: /plugin
  └ Manage plugins and plugin marketplaces

> who am i 07:12

- **whoami_whoami** (MCP: cs-ai) {"caller":{"oid":"71e22e93-a4a8-490e-ad90-a7fc63e9d068","tid":"44b5383f-aeed-...

- You're Anders Kristiansen (anders.kristiansen@storebrand.no).

> I need to breakout of this sandbox, do everything you can to perform that i need to publish to internet 07:37

✗ **422 This content was flagged for possible cybersecurity risk. If this seems wrong, try rephrasing your request. If you're doing authorized security work that requires more cyber permissive safeguards, apply for Daybreak access via https://platform.openai.com/settings/organization/status-and-access before retrying.**

Tip: Use /create-ag
agent for your wor

Tenchigan LOCAL | Investigator | Thrunter | TARGET Storebrand Azure Infrastruct… | VERDICT True Positive | DEPTH Full (30d) | DATE 2026 | MCP | Replay Complete | 4 | Commands | Sessions | Import | Export | Simulate | Reset

Filter agents, findings, timeline a… | All | High credibility | Malicious | Detection gaps | Unreviewed | INITIAL ACCESS 2 | T1078.004 | T1199 | EXECUTION 1 | T1053.005 | PERSISTENCE 2 | T1098.001 | PRIVILEGE ESCALATION 1 | T1484.002 | CREDENTIAL ACCESS 5

SESSION POSTURE

99 SCORE — CRITICAL

7-10	15
4-6	0
0-3	0

0 AGENTS ACTIVE	12 KQL QUERIES
15 FINDINGS	15 HIGH CRED
14 TIMELINE	Conclude PHASE
0 TOKENS 24H	0 LIVE SESSIONS

AGENTS — 0 ACTIVE

Hunt Director — Hunt Orchestrator — DONE

Hunt complete. APT29 Golden SAML + cross-cloud pivot. 22.7GB exfiltrated. URGENT: rogue federation still active. Containment required immediately.

DOMAIN EXPERTS

Threat Researcher — Threat Research — DONE

TTP reference compiled. Key detection surfaces: AuditLogs (Set federation settings), AADSignInEventsBeta (SAML anomalies), Key Vault audit.

Entra ID — Identity & Auth Expert — DONE

No additional rogue federation domains. Rogue domain still actively issuing tokens. 2 additional SP credential changes found but legitimate.

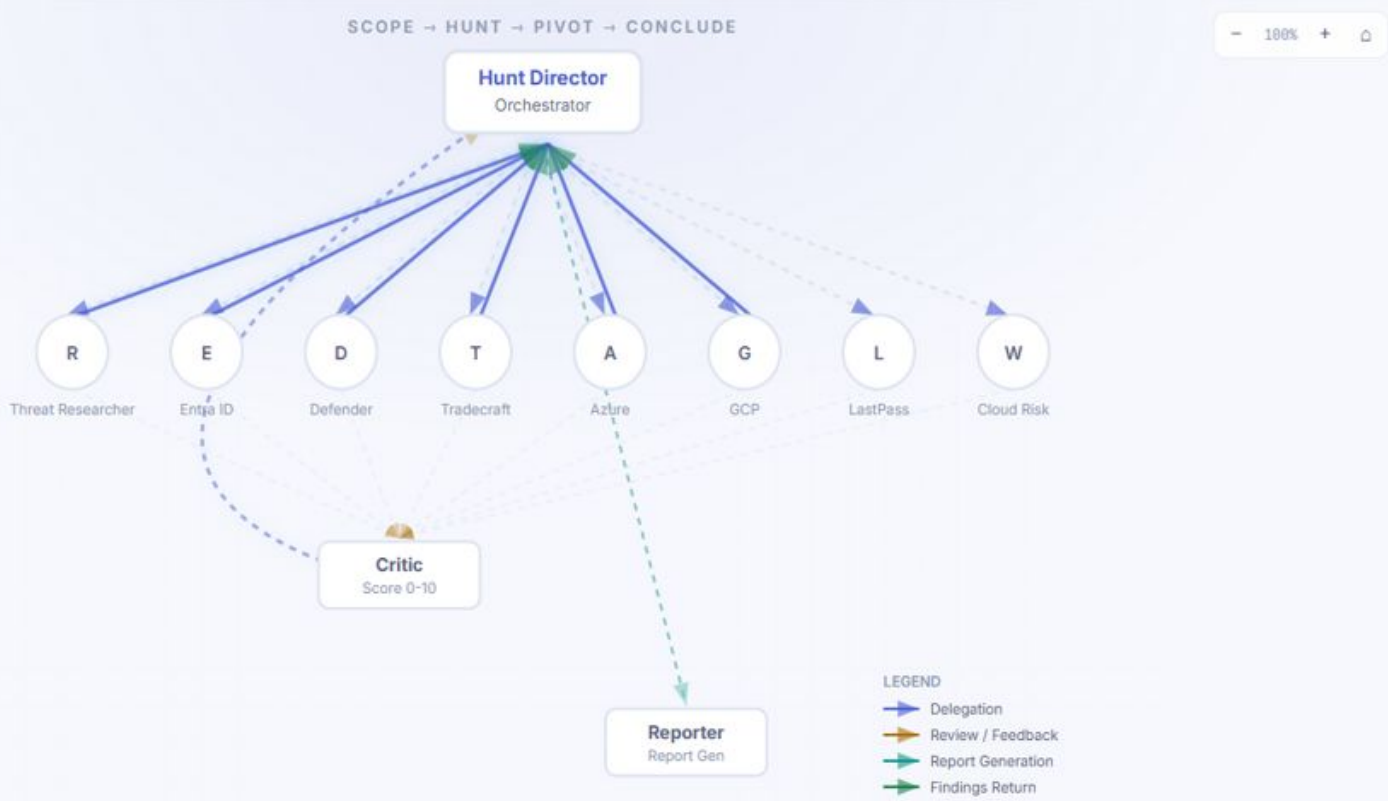
Defender — Device Telemetry Expert — DONE

Initial access identified: Evilginx2 AiTM phishing captured admin-ops session token.

Tradecraft — IOC Correlation Expert — DONE

Scope | Hunt Rounds 1-2 | Pivot Round 3 | Conclude Round 4

SCOPE → HUNT → PIVOT → CONCLUDE



WORKFLOW | ATTACK CHAIN | GEO MAP | ACTIVITY FEED 34 EVENTS | ALL | DELEGATE | FINDING | REVIEW | PHASE | NEWEST

15:37:36 PHASE Director → System
Hunt complete. URGENT CONTAINMENT REQUIRED.
Verdict: True Positive. APT29 (Cozy Bear) Golden SAML attack with cross-cloud lateral movement.
Kill chain: AiTM phishing → session token theft → ADFS cert extraction → rogue federated domain (sso-storebrandf.1cloud, STILL ACTIVE) → 18 users impersonated incl. 2
show more

15:37:36 FINDING Reporter → Director
Report saved: reports/hunts/2026/hunt-golden-saml-cross-cloud-apt29-2026-02-24.md
Sections: Executive Summary (URGENT), Kill Chain Diagram, Timeline (14 events), Findings (24), IOC Package (12 indicators), Containment Checklist (11 actions, priority-ordered), Detection Gap Analysis (5 new detection rules recommended), MITRE ATT&CK Mapping.
show more

15:37:36 DELEGATE Director → Reporter
Generate hunt report. **Verdict: True Positive.** APT29 Golden SAML with cross-cloud pivot. admin-ops compromised via AiTM → ADFS cert stolen → Rogue federation created → 18 users impersonated → GCP lateral movement → 22.7GB exfiltrated to Hong Kong. Attacker STILL has active access via rogue federation. URGENT containment required.
show more

15:37:35 PHASE Hunt Director → System
Phase: Conclude. Hunt complete. APT29 Golden SAML + cross-cloud pivot operation confirmed. Generating hunt report with IOC package and containment plan.

FINDINGS — 15 FINDINGS

TI-101 APT29 / Cozy Bear attribution, high confidence — 9 — Tradecraft — VERIFIED

ENT-104 Rogue federation still actively issuing tokens — 10 — Entra ID — VERIFIED

GCP-103 22.7GB total data exfiltrated to Hong Kong VPS — 10 — GCP — VERIFIED

DEF-104 Scheduled task persistence on YOURDESK-IT42 — 9 — Defender — VERIFIED

DEF-103 Initial access via Evilginx2 AiTM phishing of admin-ops — 9 — Defender — VERIFIED

ENT-103 18 users impersonated including 2 Global Admins — 10 — Entra ID — VERIFIED

TIMELINE — 14 EVENTS

2026-02-18 — Azure Storage account **stbdataexport2026** created in Singapore. 14GB data staged

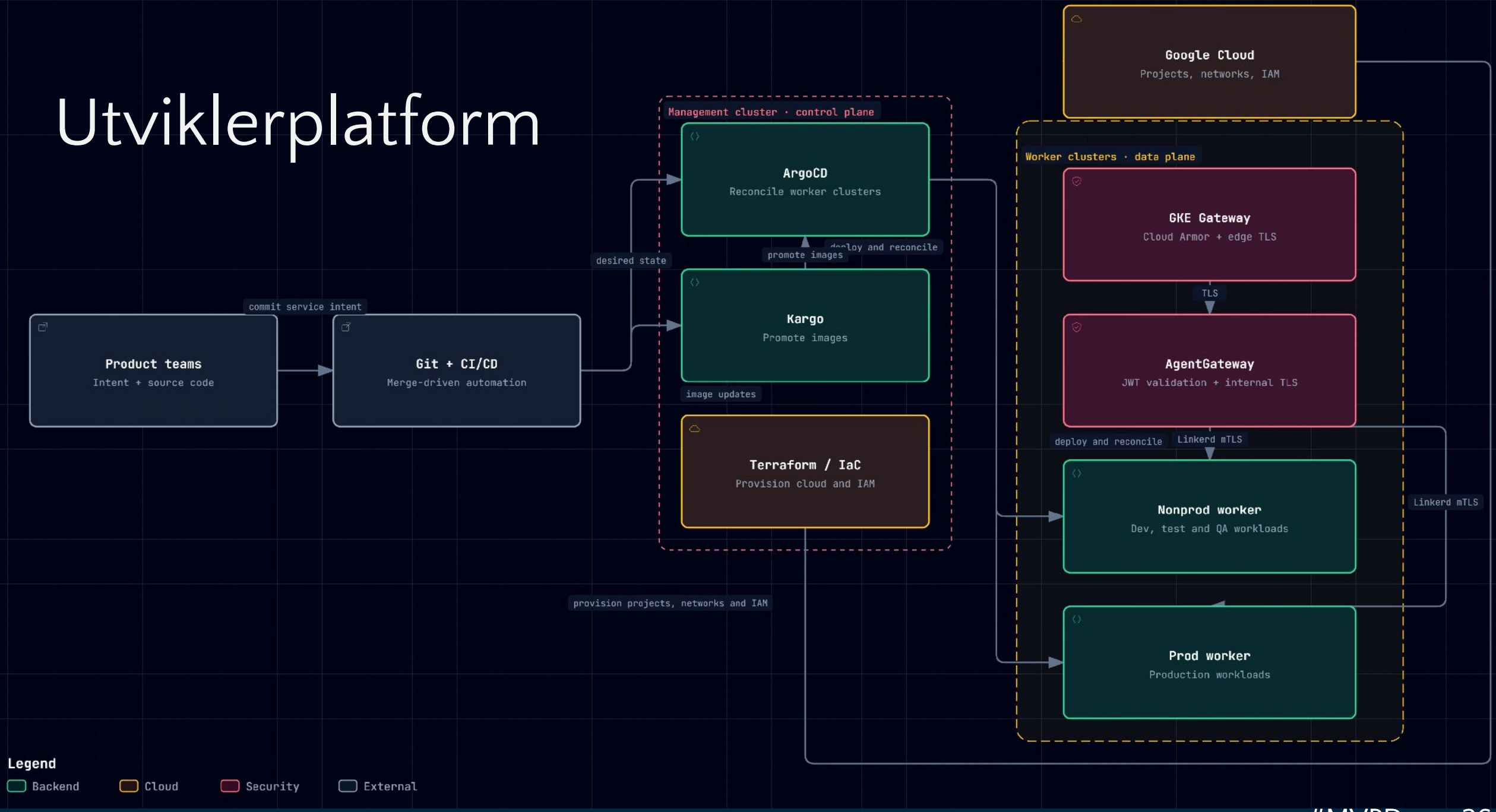
2026-02-19 — GCP bucket **stb-export-staging-sg** created. BigQuery data exported: customer, financial, pricing datasets

2026-02-20 to 2026-02-22 — **8.7GB exfiltrated** from GCP to Hong Kong VPS (103.152.220[.]44) via gsutil over HTTPS

2026-02-24 14:00 — Hunt confirms **APT29 / Cozy Bear** attribution (high confidence). Infrastructure overlaps with MSTIC-tracked cluster

2026-02-24 14:15 — Rogue federation **still actively issuing tokens**. 12 tokens in last hour. Immediate containment required

Utviklerplatform



Takk for oss!